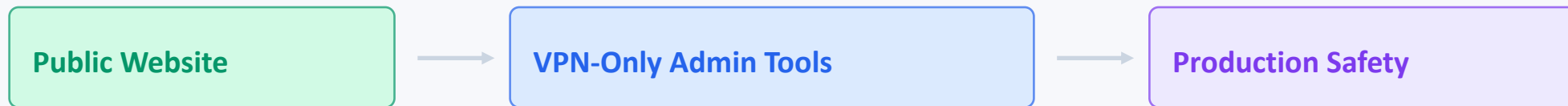


VPN System Design for ApexTrainer

Separating the public website from internal services such as Langflow, Portainer, SSH, databases, and internal APIs



The Problem to Solve

The public website must remain accessible, while administrative services should not be exposed to the Internet

Can Be Public

- Users can access ApexTrainer
- Login and use the fitness application
- Protected with HTTPS

Should Not Be Public

- Langflow contains API keys and flows
- Portainer can control Docker
- Databases and SSH are high-risk services

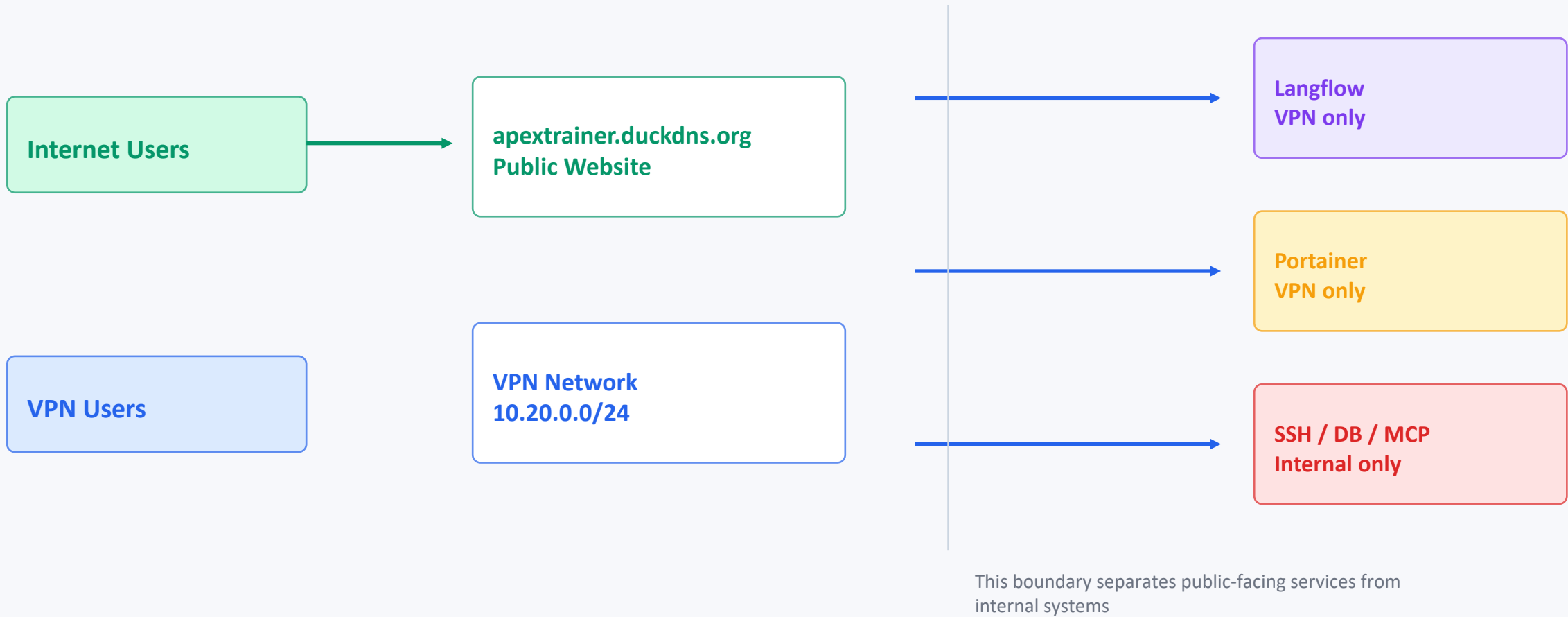
Use VPN for Access Control

- Access only for authorized team members
- Internal systems accessed through VPN
- Reduces the attack surface

Core idea: keep only the main website public, while administrative tools are accessible only through the VPN.

Recommended Architecture

Split traffic into two paths: public access and VPN-only access



VPN Options

Comparison of WireGuard, OpenVPN, and Headscale for the project team

WireGuard

Fast, lightweight, and easy to install

Best for demos and small teams

OpenVPN

Detailed policy management

Best for organizations or legacy environments

Headscale

Self-hosted device management similar to Tailscale

Best for teams with many devices

Recommendation: use WireGuard for a quick implementation; choose Headscale when managing many users and devices.

Recommended Approach for ApexTrainer

Start with WireGuard for the demo, then expand to Headscale when more devices must be managed

WireGuard

- Easy to install on the server
- Create a peer for each team member
- Restrict Langflow and Portainer to VPN IP addresses

Security Goal

- Public: main website only
- Private: administrative tools
- Block sensitive ports from the Internet

Public Website

VPN Access

Admin Tools

Monitoring

WireGuard VPN Implementation

Fast to deploy and easy to demonstrate

1

Install WireGuard on the server

Open a UDP port such as 51820

2

Generate server and peer keys

Give each team member an individual configuration

3

Define the VPN subnet

Example: 10.20.0.0/24

4

Configure the firewall and reverse proxy

Allow Langflow and Portainer only from VPN IPs

Example flow: a team member connects to WireGuard → receives a 10.20.0.x address → can access Langflow and Portainer.

Protecting Project Domains

Apply different policies based on the risk level of each service

apextrainer.duckdns.org

Public

Publicly accessible through HTTPS

langflow.apextrainer.duckdns.org

VPN Only

Contains flows, keys, prompts, and tool configuration

portainer.apextrainer.duckdns.org

VPN Only

Can control Docker and the server

PostgreSQL / MCP / SSH

Internal Only

Do not expose ports to the Internet

Principle: public domains require HTTPS and authentication, while administrative domains require an active VPN connection.

Firewall and Reverse Proxy Rules

Close unnecessary ports and require VPN access for administrative domains

Open to the Internet

- 80/tcp: redirect to HTTPS
- 443/tcp: public website
- 51820/udp: WireGuard VPN

Closed or Restricted

- 3010 backend
- 5432 PostgreSQL
- 7860 Langflow
- 9000/9443 Portainer
- 22 SSH through VPN only

Reverse Proxy Policy

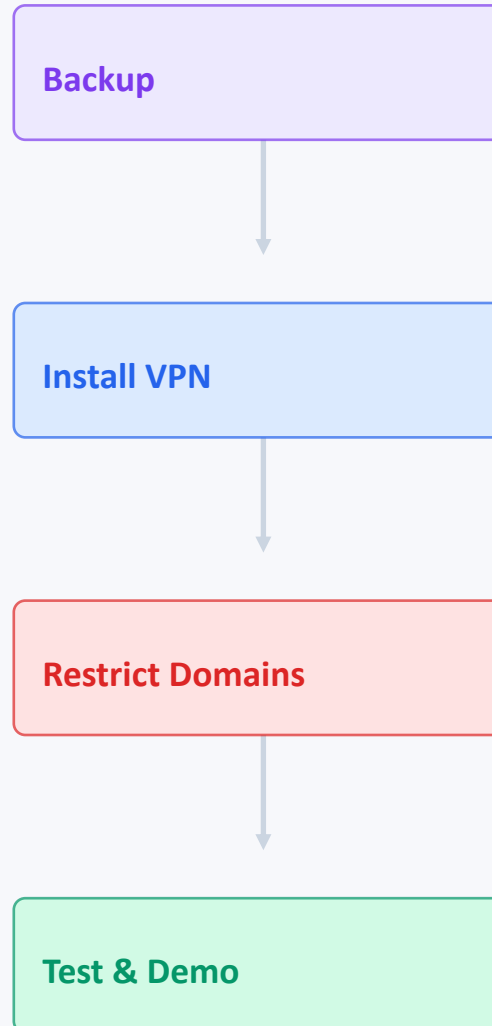
- Public website → allowed
- Langflow → VPN subnet only
- Portainer → VPN subnet only

Example VPN subnet: 10.20.0.0/24 — use a `remote_ip` rule to allow only clients connected through the VPN.

Implementation Checklist

Deployment steps for integrating VPN access into ApexTrainer

- Back up the server and database before changing network settings
- Install WireGuard or Headscale
- Create user or device access for team members
- Configure the firewall to expose only ports 80, 443, and the VPN port
- Configure Caddy or Nginx so Langflow and Portainer are VPN-only
- Test the public website from the Internet
- Test administrative tools after connecting to the VPN
- Document the architecture and credential policy



Demonstration Flow

Show how the VPN protects administrative systems

Step 1

Open the Public Website

The main website remains accessible

Step 2

Try Langflow and Portainer without VPN

Access should be denied or return HTTP 403

Step 3

Connect to the VPN and try again

Only authorized team members can access Langflow and Portainer

Step 4

Disconnect the VPN and test again

Confirm that administrative services are protected

Summary: the VPN keeps the ApexTrainer website public while protecting administrative tools from Internet access.

Final Proposal

Use VPN access control to reduce production security risks

Public

ApexTrainer Website
For general users

VPN Only

Langflow / Portainer
For the project team

Internal

Database / SSH / MCP
Not exposed to the Internet

Final recommendation: begin with WireGuard for a fast and reliable demo, then move to Headscale for long-term management of many users and devices.

Detailed WireGuard Setup — Server Installation

Commands for an Ubuntu/Debian production server. Replace placeholders before use.

1 Install and generate keys

SERVER TERMINAL

```
sudo apt update && sudo apt install -y wireguard
sudo mkdir -p /etc/wireguard
sudo sh -c "umask 077; wg genkey > /etc/wireguard/server.key"
sudo sh -c "wg pubkey < /etc/wireguard/server.key > /etc/wireguard/server.pub"
umask 077
wg genkey > client1.key
wg pubkey < client1.key > client1.pub
sudo cat /etc/wireguard/server.pub
cat client1.pub
```

2 Create the server configuration

WG0.CONF

```
sudo nano /etc/wireguard/wg0.conf

[Interface]
Address = 10.20.0.1/24
ListenPort = 51820
PrivateKey = <SERVER_PRIVATE_KEY>
SaveConfig = true

[Peer]
PublicKey = <CLIENT1_PUBLIC_KEY>
AllowedIPs = 10.20.0.2/32
```

Keep private keys secret. Create one peer and one VPN IP address for each team member.

Detailed WireGuard Setup — Firewall, Access Control, and Testing

Bring up the VPN, restrict admin domains, then validate public and private access.

3 Start WireGuard

ENABLE VPN

```
sudo systemctl enable --now wg-quick@wg0
sudo wg show
sudo ss -ltnp | grep 51820
```

4 Configure the firewall

UFW

```
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw allow 51820/udp
sudo ufw allow from 10.20.0.0/24 to any port 22 proto tcp
sudo ufw enable
```

5 Create the client profile

CLIENT1.CONF

```
[Interface]
Address = 10.20.0.2/32
PrivateKey = <CLIENT_PRIVATE_KEY>

[Peer]
PublicKey = <SERVER_PUBLIC_KEY>
Endpoint = <SERVER_PUBLIC_IP>:51820
AllowedIPs = 10.20.0.0/24
PersistentKeepalive = 25
```

6 Restrict Langflow and Portainer in Caddy

CADDYFILE

```
langflow.apextrainer.duckdns.org {
  @notVPN not remote_ip 10.20.0.0/24
  respond @notVPN "VPN connection required" 403
  reverse_proxy apextrainer-langflow:7860
}

portainer.apextrainer.duckdns.org {
  @notVPN not remote_ip 10.20.0.0/24
  respond @notVPN "VPN connection required" 403
  reverse_proxy portainer:9000
}
```

Validation

- Public website works without VPN
- Langflow returns 403 without VPN
- Connect VPN and retry
- Langflow and Portainer become accessible
- Disconnect VPN and confirm access is blocked

Safety note: keep the current SSH session open while testing UFW. Do not remove public SSH access until VPN access has been verified.